

Risk Management & Threat Modeling

The Risk Formula

Risk = Likelihood × Impact (at its simplest). More precisely:

- Asset – what you value (data, systems, reputation)
- Threat – what could harm it (attacker, disaster)
- Vulnerability – the weakness that makes the harm possible
- Impact – how bad it is when it happens

The Risk Equation Everyone Uses

Risk = (Threat × Vulnerability) × Asset Value

Reduce risk by: reducing threats (unlikely), removing vulnerabilities (possible), or reducing asset exposure (possible).

Risk Response Options (Mitigate Doesn't Mean Prevent)

Response	Meaning	Example
Mitigate	Reduce likelihood/impact	patches, MFA
Transfer	Move the risk	cyber insurance
Accept	Acknowledge and tolerate	low-impact, low-likelihood
Avoid	Remove the risky thing	stop offering that service

Threat Modeling with STRIDE

- Spoofing – pretending to be someone else
- Tampering – modifying data
- Repudiation – denying an action
- Information disclosure – leaking data

Denial of service – making unavailable Elevation of privilege – gaining more rights

Apply STRIDE per data-flow, component, and trust boundary. For each threat ask: can this happen? like how? what control stops it?

Threat Modeling with DREAD (Risk Prioritization)

Damage potential – how severe? Reproducibility – how easy to trigger again? Exploitability – how hard to exploit? Affected users – how many? Discoverability – how easy to find?

Score 0-10 each, sum, and rank. DREAD is a scoring aid; STRIDE is a discovery aid. Together: discover with STRIDE, prioritize with DREAD.

The Asset Inventory Comes First

You cannot protect what you don't know exists. Threat modeling starts with an asset inventory: data, servers, accounts, network segments, third parties, and a data-flow diagram.

Security through refusal: if you can't list your assets and draw the data flows, any "security" is theater. This is the first question auditors and CISOs ask.

[← Threat Actors & Their Motiva...](#)

[Security Controls: Prevent, De...](#)